

SOC TO CISO · PRODUCT INTEGRATION

MERIDIAN + LODESTAR

Integration design and deployment — high-level design, contract, deployment, security and operations

How MERIDIAN hands its SOC cases and health to LODESTAR: what crosses and what does not, the signed webhook contract field by field, how identities are mapped so both products agree on which asset matters, the network and secret set-up on Azure and AWS, the threats and their controls, how to run and troubleshoot it, and the evidence that it works end to end.

DOCUMENT

INT-00

VERSION

1.0.0

DIRECTION

One way

CADENCE

Hourly

DATE

2 October 2026

Contents

1 What the integration is for	3
2 High-level design	4
3 Interfaces at a glance	6
4 Low-level design: the contract	7
5 Identity: making both products agree	9
6 Flows	10
7 Deployment	12
8 Security	14
9 Operations, troubleshooting and evidence	15
10 Open items and roadmap	17

Integrating MERIDIAN with LODESTAR

The SOC engine decides what happened. The CISO platform decides what matters most today. This document is the contract between them.

WHAT THIS DOCUMENT IS, AND WHO OWNS WHICH PART

This is the design and build document for the hand-off from MERIDIAN (detection, triage, investigation and containment) to LODESTAR (risk prioritisation, KRIs and board reporting). It is written for the engineers of both products and for the assessor who has to sign off the data flow.

- **MERIDIAN owns** the payload: what is sent, when, and how it is signed (`meridian/integrations.py`, the scheduler's `lodestar` step).
- **LODESTAR owns** the receiving end: the signed ingest endpoint, the webhook inbox and how a SOC finding is scored (`lodestar/api/app.py`, the webhook adapter, `lodestar/scoring.py`).
- **Both own** the contract in section 4 and the shared context in section 5. A change to either needs a change to this document and a green contract test (section 9).

The deployment documents for each cloud are AZ-00 and AWS-00. This document adds only what the integration needs.

1 What the integration is for

WHAT IT GIVES

- **One list for the CISO.** A confirmed incident on a business-critical asset appears on LODESTAR's Today list alongside the vulnerability, identity and exposure findings it may be connected to, with the reason stated.
- **Measured SOC KRIs.** Mean time to detect, mean time to respond, open incidents and silent log sources are measured by MERIDIAN and reported by LODESTAR, instead of being typed into a spreadsheet each month.
- **Agreement on what matters.** Both products read the same CMDB. The asset MERIDIAN reports is the most critical one the incident reached, and LODESTAR scores it with the same criticality.
- **No coupling at run time.** If either product is down, the other keeps working. A missed push loses nothing, because each push is a complete snapshot.

WHAT IT DOES NOT DO

- **It is one way.** LODESTAR never calls MERIDIAN, and MERIDIAN never reads LODESTAR. A risk acceptance or owner assignment in LODESTAR does not flow back to the SOC (section 10).
- **It does not carry telemetry.** No raw events, command lines, sample records, file contents or credentials cross. Only case-level facts and aggregate KPIs do.
- **It does not grant actions.** Nothing LODESTAR receives can trigger a containment action in MERIDIAN. Containment remains four-eyes approval inside MERIDIAN.

2 High-level design

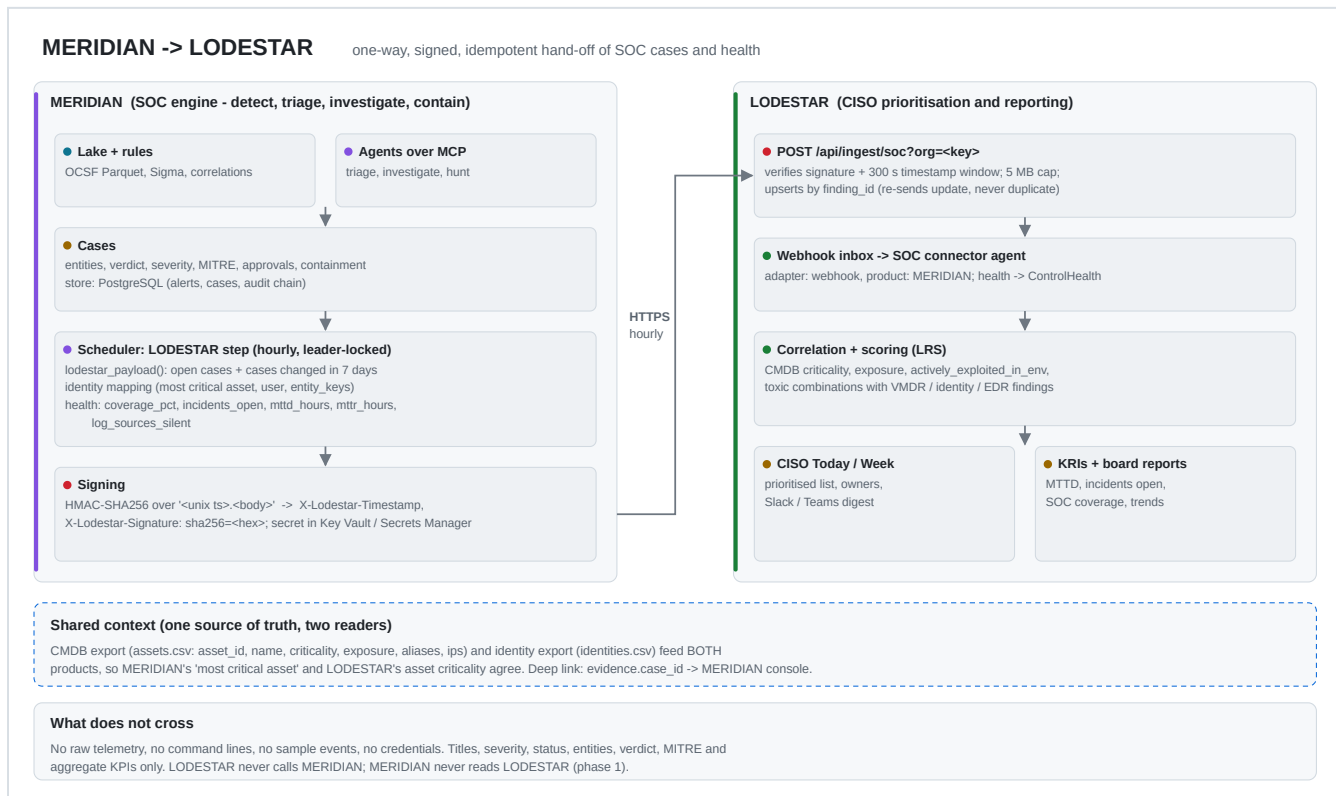


Figure 2.1 The integration. MERIDIAN signs and pushes; LODESTAR verifies, stores, correlates and reports. Both read the same CMDB.

Responsibilities

Concern	MERIDIAN	LODESTAR
Detects and investigates the incident	Yes: rules, correlations, triage and investigation agents	No
Decides the verdict and contains	Yes, with human approval	No
Decides how urgent the incident is against everything else	No	Yes: LODESTAR Risk Score (LRS) and horizon (Today, Week, Month, Backlog)
Correlates with vulnerabilities, identity risk and threat intelligence	Only within security telemetry	Yes, across all connected domains
Measures SOC KPIs	Yes: MTTD, MTTR, open incidents, silent sources, coverage	Reports them as KRIs against appetite
Holds the CMDB and identity export	Reads a copy	Reads a copy

Design principles

- State, not events.** Each push carries the current state of every open case and of every case that changed in the last seven days. Re-sending is safe and normal; nothing depends on a single message arriving.
- Idempotent by identity.** finding_id = meridian-<case_id>. LODESTAR upserts on it, so a case is one item for its whole life, whatever its status.

-
3. **Signed, fresh and scoped.** HMAC-SHA256 over the timestamp and body, a five-minute window, and a secret per LODESTAR organisation.
 4. **Least data.** Titles, severity, status, entities, verdict, MITRE techniques and aggregates only.
 5. **Failure is isolated.** A failed push is logged, exported as a metric and retried next cycle. It never blocks detection, triage or response.

3 Interfaces at a glance

Property	Value
Direction	MERIDIAN → LODESTAR only
Transport	HTTPS POST, TLS verified against the system trust store (SSL_CERT_FILE for a private CA); proxy settings honoured
Endpoint	<LODESTAR_URL>/api/ingest/soc?org=<org key> (org omitted when LODESTAR serves one organisation)
Content type	application/json, UTF-8
Authentication	X-Lodestar-Timestamp: <unix seconds> and X-Lodestar-Signature: sha256=<hex HMAC-SHA256(secret, "<timestamp>.<body>")>
Replay window	±300 seconds; required when LODESTAR sets security.webhook_require_timestamp: true (recommended)
Size limit	5 MB per request (413 above it); a full push of 500 cases is about 1 MB
Cadence	Hourly, from the MERIDIAN scheduler (one leader at a time)
Timeout	30 seconds per request; no retry within a cycle
Success	202 {"accepted": <n>}
Sender	MERIDIAN scheduler role (ECS task or Container App)
Receiver	LODESTAR API, then the SOC connector agent on its next run

4 Low-level design: the contract

Envelope

```
{
  "findings": [ <finding>, ... ],
  "health": {
    "coverage_pct": 92,
    "kpis": {"incidents_open": 6, "mttd_hours": 0.4, "mttr_hours": 5.2, "log_sources_silent": 1}
  }
}
```

LODESTAR stores each finding in its webhook inbox under domain `soc` and the organisation from `?org=`, and stores `health` as the SOC control's health. A body with only `health` is valid (a quiet hour still reports KPIs).

Finding fields

Field	Value from MERIDIAN	Rule
finding_id	meridian-<case_id>	Stable for the life of the case: the upsert key
source	meridian	
finding_type	incident	
title	Case title	At most 300 characters
description	Case summary (the analyst's or agent's)	At most 2,000 characters
severity	Case severity mapped below	
status	Case status mapped below	
asset_id	Most critical device, cloud account or resource the case reached	Never an IP address; LODESTAR resolves it against the CMDB by id, name, alias or external id
user_id	The user entity, or the first user seen in the case's sample events	Lower-cased
entity_keys	Every other entity of the case (IPs, hashes, domains, other hosts)	Up to 50; used by LODESTAR for cross-domain correlation
actively_exploited_in_env	true when the verdict is malicious and the case is not resolved	Suspicious and inconclusive cases are false
first_seen, last_seen	Case created and updated time, ISO 8601 UTC	
evidence	case_id, verdict, mitre (technique ids), entity, entity_type	case_id is the deep-link key back to the MERIDIAN console

Severity and status mapping

MERIDIAN severity	LODESTAR severity	MERIDIAN case status or verdict	LODESTAR status
1	info	new, triaged	open
2	low	investigating, awaiting_approval, contained	in_progress
3 (and unset)	medium	closed	resolved
4	high	verdict benign (any status)	false_positive
5, 6	critical		

Which cases are sent

Every case that is not closed, plus every case that changed in the last **seven days**, up to the 500 most recently updated. A closed case is therefore re-sent for a week, so LODESTAR learns the resolution even if a push was missed. LODESTAR keeps an inbox item for **30 days** after it was last received (`retention_days` on the webhook adapter), so an open case, re-sent every hour, never ages out.

Health and KPIs to LODESTAR KRIs

MERIDIAN field	How MERIDIAN measures it	LODESTAR use
health.coverage_pct	Configured sources that delivered a batch in the last 24 hours, as a percentage	SOC control health (coverage)
kpis.incidents_open	Cases not closed	Executive summary and board report: open incidents
kpis.mttdd_hours	Mean of (first alert raised – first event seen) for cases opened in 30 days	KRI mttdd_hours (appetite 4 h by default, lower is better)
kpis.mttr_hours	Mean of (contained or closed – opened) for cases closed or contained in 30 days	SOC KPI mttr_hours
kpis.log_sources_silent	Configured sources with no batch in 24 hours	SOC KPI log_sources_silent
(not sent)		SOC KPI attack_coverage_pct shows as not measured (section 10)

5 Identity: making both products agree

The integration is only as good as its identity mapping. If MERIDIAN reports the workstation where a phishing chain started, while the incident reached the file server, LODESTAR will score a low-criticality workstation and the incident lands on Week instead of Today.

Entity in the MERIDIAN case	Goes to	Why
Device, cloud account, resource	asset_id (the most critical one, by CMDB criticality)	LODESTAR scores the asset's criticality and exposure
User (UPN or e-mail)	user_id	LODESTAR correlates with identity risk (risky users, MFA gaps)
IP address (source, destination)	entity_keys only	An attacker IP must never create or match an asset
Anything else (hash, domain, URL, other hosts)	entity_keys	Correlation with intelligence and exposure findings

THE SHARED CONTEXT IS A DEPLOYMENT REQUIREMENT, NOT AN OPTION

Both products must load the **same** CMDB export (assets.csv: asset id, name, criticality, exposure, aliases, IPs, external ids) and identity export (identities.csv). Produce them once, from the system of record, and deliver the same files to both: a storage container or bucket that both read, or the same CI job publishing to both images. If the two copies diverge, MERIDIAN may pick one asset as the most critical while LODESTAR scores another, and the Today list will be wrong without any error.

Worked example

A phishing e-mail leads to execution on workstation ws-0142 (criticality 2), then to access from that workstation to file server fs-01 (criticality 5, business service "File services"). The investigation agent returns **malicious**.

- MERIDIAN sends asset_id = fs-01, user_id = j.doe@corp.example, the sender domain and source IP in entity_keys, severity = critical, actively_exploited_in_env = true.
- LODESTAR places the item on **Today**, because active exploitation on an asset of criticality ≥ 4 is placed on Today regardless of score. It gives two reasons: "Active exploitation / threat activity observed in our environment" and "Business-critical asset (File services)".

6 Flows

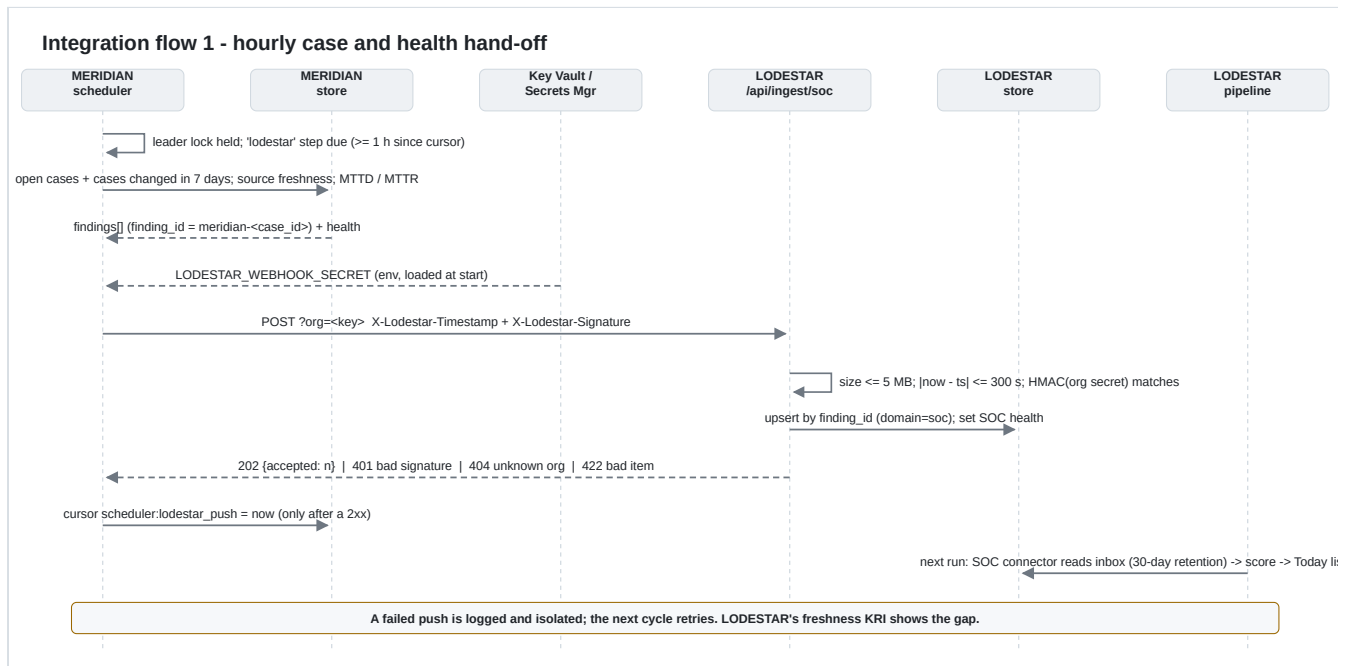


Figure 6.1 The hourly hand-off. The cursor advances only after a 2xx, so a rejected push is retried next cycle.

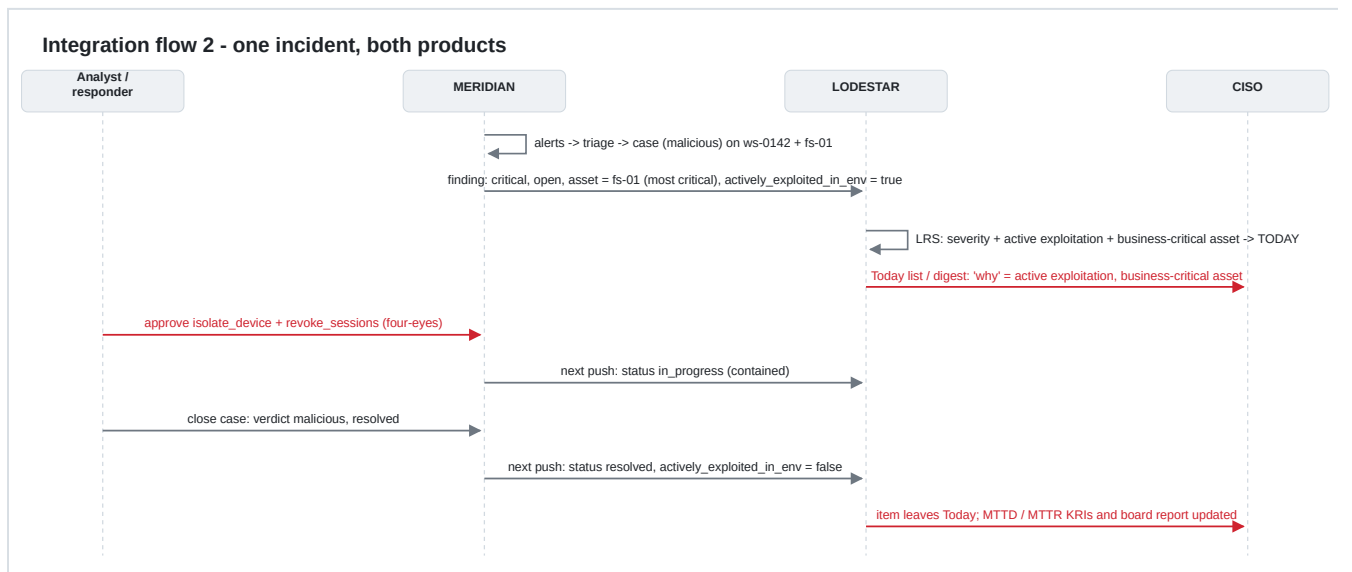


Figure 6.2 One incident across both products: it enters Today when MERIDIAN confirms it and leaves when MERIDIAN resolves it.

Timing

Event	Worst-case delay to LODESTAR
Case opened or changed in MERIDIAN	Up to 1 hour (next push)
Push received	Visible in LODESTAR's inbox immediately; scored on LODESTAR's next pipeline run (lodestar schedule, every 4 hours by default; set --interval-hours 1 to match MERIDIAN)
Push rejected	Retried every scheduler cycle until accepted; the metric shows the age

Event	Worst-case delay to LODESTAR
MERIDIAN down for a day	No loss: the first push after recovery carries the full current state
LODESTAR down for a day	No loss: same as above. LODESTAR's SOC freshness shows the gap meanwhile

7 Deployment

Network path

LODESTAR's ingest endpoint should be reachable **privately** from MERIDIAN's scheduler. Neither product needs public exposure for this integration.

Placement	Azure	AWS
Same network	LODESTAR in the same VNet or a peered VNet; private DNS zone for its hostname	LODESTAR behind an internal ALB in the same or a peered VPC (or Transit Gateway); Route 53 private hosted zone
Egress rule	The Container Apps subnet's NSG (or Azure Firewall) allows TCP 443 to LODESTAR's private address	The app security group allows egress; restrict it to LODESTAR's CIDR on 443 if your baseline requires explicit egress
Across clouds or on-premises	VPN or ExpressRoute to the network hosting LODESTAR	Site-to-site VPN or Direct Connect
TLS	LODESTAR's certificate from your private CA: add the CA to the image and set <code>SSL_CERT_FILE</code> . Never disable verification	Same

Configuration on each side

Side	Setting	Value
MERIDIAN (Terraform)	<code>lodestar_url, lodestar_org</code>	LODESTAR base URL (must be <code>https://</code>) and organisation key; empty <code>lodestar_url</code> switches the integration off
MERIDIAN (secret)	<code>lodestar-webhook-secret</code> in Key Vault or Secrets Manager → <code>LODESTAR_WEBHOOK_SECRET</code>	At least 32 random bytes, hex or base64
MERIDIAN (config)	<code>lodestar: {url: \${LODESTAR_URL}, org: \${LODESTAR_ORG}, webhook_secret: \${LODESTAR_WEBHOOK_SECRET}}</code>	Already in <code>config/examples/azure.yaml</code> and <code>aws.yaml</code>
LODESTAR (config)	<code>connectors.soc: {enabled: true, adapter: webhook, product: MERIDIAN}</code>	In the organisation's tenant file when multi-tenant
LODESTAR (config)	<code>security.webhook_require_timestamp: true</code>	Rejects unsigned-time or replayed requests
LODESTAR (secret)	<code>LODESTAR_WEBHOOK_SECRET_<ORG_KEY></code> (upper case, - → _)	The same value as MERIDIAN's secret. Mandatory when LODESTAR serves several organisations
Both	CMDB and identity exports	The same files (section 5)

WHY THE SECRET MUST BE PER ORGANISATION

The `?org=` parameter is not covered by the signature. With one secret shared across organisations, a sender holding it could write into another organisation's inbox by changing the parameter. LODESTAR therefore refuses a shared secret when more than one organisation is configured, and each MERIDIAN deployment must hold only its own organisation's secret.

Steps

Step	Action	Done when
I0	Agree the organisation key and who owns the secret (normally the LODESTAR platform team)	Recorded in both runbooks
I1	Open the network path and private DNS; test with <code>curl -sS https://<lodestar>/healthz</code> from a MERIDIAN one-off task	200 over verified TLS
I2	Generate the secret once; store it in LODESTAR's secret store as <code>LODESTAR_WEBHOOK_SECRET_<ORG></code> and in MERIDIAN's as <code>lodestar-webhook-secret</code>	Both stores hold the same value; nobody has it in a ticket or chat
I3	Configure LODESTAR's soc connector and <code>webhook_require_timestamp</code> ; restart LODESTAR	<code>lodestar doctor</code> passes
I4	Set <code>lodestar_url</code> and <code>lodestar_org</code> , apply Terraform, redeploy the MERIDIAN scheduler	Next cycle logs a 202; <code>meridian_lodestar_last_push_status</code> 202
I5	On LODESTAR: <code>lodestar test-connector soc</code>	RESULT OK, product MERIDIAN, KPIs shown
I6	On LODESTAR: <code>lodestar run</code> , then review the Today list with the SOC lead	Open malicious cases on critical assets appear on Today with the expected reasons

8 Security

Threat	Control	Where
Someone posts fake incidents to LODESTAR	HMAC-SHA256 signature with a secret only the two products hold; 401 otherwise	LODESTAR ingest
A captured request is replayed	Timestamp inside the signed material; ± 300 s window enforced	LODESTAR ingest
One organisation writes into another's inbox	Per-organisation secret, mandatory when multi-tenant	LODESTAR _webhook_secret
Content read or altered in transit	TLS with verification; private network path	Both
Oversized or malformed requests	5 MB cap (413); JSON required (400); every item needs finding_id (422)	LODESTAR ingest
A compromised LODESTAR attacks MERIDIAN	No path exists: one-way push, no credential for MERIDIAN in LODESTAR	Design
Sensitive telemetry leaks into the board pack	Only case-level fields and aggregates are sent; descriptions are capped	MERIDIAN payload
The secret leaks	Vault-held on both sides, never in configuration; rotation below	Both
An attacker IP pollutes the CMDB	IPs go only to entity_keys, never asset_id	MERIDIAN mapping

Residency

The integration adds no new location. On Azure and on AWS, MERIDIAN's scheduler and LODESTAR run in the same region (UAE North or me-central-1). The payload never reaches a model provider: MERIDIAN's agents produced the case summaries earlier, under the controls in AZ-00 and AWS-00.

9 Operations, troubleshooting and evidence

Monitoring

Signal	Alert when
<code>meridian_lodestar_last_push_age_seconds</code>	Greater than 7,200 (two missed cycles), or -1 (never pushed)
<code>meridian_lodestar_last_push_status</code>	Not 2xx
MERIDIAN scheduler log LODESTAR rejected the push (<code><code></code>)	Any occurrence
LODESTAR SOC control freshness	Older than two hours

Troubleshooting

Symptom	Likely cause	Fix
401 Invalid or missing signature	Secrets differ, or LODESTAR has no <code>LODESTAR_WEBHOOK_SECRET_<ORG></code>	Compare the values' SHA-256 on both sides, never the values themselves
401 Missing or stale timestamp	Clock skew over five minutes	Fix NTP on the host running LODESTAR; Fargate and Container Apps keep time
404 Unknown org	<code>lodestar_org</code> does not match a LODESTAR tenant key	Correct the variable
400 Several organisations are configured	<code>lodestar_org</code> is empty against a multi-tenant LODESTAR	Set it
413 Payload too large	Over 5 MB: an unusually large backlog of open cases	Close or merge stale cases; the 500-case cap normally prevents this
422 Every item needs a finding_id	A payload built by something other than MERIDIAN	Not expected from MERIDIAN; check the sender
202, but an item is missing in LODESTAR	LODESTAR validates items when its connector reads the inbox	<code>lodestar run</code> warnings: "rejected webhook payload" names the field
Incident on Week, not Today	Asset not matched in the CMDB, or criticality below 4, or verdict not malicious	Check the CMDB row and aliases; check the case verdict
Timeouts	Network path or private DNS	Repeat step I1 from a one-off task

Secret rotation

LODESTAR holds one secret per organisation, so rotation has a short window in which pushes are rejected. Because every push is a full snapshot, nothing is lost.

1. Generate the new value.
2. Write it to MERIDIAN's `lodestar-webhook-secret` and to LODESTAR's `LODESTAR_WEBHOOK_SECRET_<ORG>` in the same change window.
3. Restart LODESTAR's API, then redeploy MERIDIAN's scheduler.
4. Confirm `meridian_lodestar_last_push_status` 202 within the hour.

Rotate at least annually and whenever someone who could read either secret leaves.

Test evidence

Test	Result
tests/test_integrations.py: payload, signature, scheduler isolation, cursor advances only after 2xx, status metric	Pass
tests/test_lodestar_contract.py: payload shape, identity mapping, most-critical-asset selection	Pass
Contract against LODESTAR's own Finding model (LODESTAR_PATH set; CI job lodestar-contract checks out manabouprj/Lodestar)	Pass
Live: MERIDIAN demo estate pushed to a running LODESTAR with webhook_require_timestamp: true	202 Accepted
Live: the same push repeated	202, items updated, no duplicates
Live: push with a wrong secret	401
Live: lodestar test-connector soc	RESULT OK; health and KPIs passed through
Live: lodestar run	The phishing case appears on Today with asset FS-01 and the reasons "Active exploitation / threat activity observed in our environment" and "Business-critical asset (File services)"

Go-live checklist

- Steps I0–I6 complete, with evidence filed.
- The shared CMDB and identity exports are produced by one job and delivered to both products.
- The two monitoring alerts are configured and have fired once in a test.
- The SOC lead and the CISO's office have reviewed one week of Today items that came from MERIDIAN.

10 Open items and roadmap

Item	Position
One way only	Decisions in LODESTAR (risk acceptance, owner, due date) do not reach MERIDIAN. Roadmap: a read-only MCP context tool in MERIDIAN exposing LODESTAR's priority and owner for an asset, so agents can cite it
No dual-secret rotation	LODESTAR accepts one secret per organisation; rotation is a coordinated change (section 9). Roadmap: accept a current and a next secret
attack_coverage_pct not sent	MERIDIAN knows each rule's ATT&CK techniques but has no agreed denominator. Roadmap: coverage against the institution's threat profile from LODESTAR's vertical
500-case cap per push	Sufficient for normal volumes; a backlog beyond it drops the oldest-updated open cases from the push until it is reduced
No deep link rendered	evidence.case_id is carried; a console link template in LODESTAR is a roadmap item
Hourly cadence	Adequate for prioritisation and reporting. Critical cases already reach people through MERIDIAN's own chat notifications without waiting for LODESTAR